10. - Ataques Wi-Fi - Recon MGT

Introducción

Ataques Wi-Fi - Recon MGT

El reconocimiento previo a un ataque es una fase crucial que nos permite recolectar información sobre la red y los dispositivos conectados antes de lanzar un ataque más elaborado. A continuación, se presentan técnicas y herramientas usadas frecuentemente para realizar un reconocimiento efectivo en redes MGT.

Análisis de Identidades de Usuarios

En las redes Wi-Fi que utilizan WPA/WPA2/WPA3-Enterprise (WPA MGT), las identidades sirven para autenticar a los usuarios y dispositivos que intentan conectarse a la red, es decir, en el contexto de redes Wi-Fi MGT es el equivalente al nombre de usuario para iniciar sesión. Por diseño, estas identidades se envían antes de crear el túnel TLS para cifrar la autenticación, por lo que con una monitorización pasiva es posible obtener los nombres de usuarios de los clientes de la red cuando se autentican. Para mitigar esto se pueden utilizar identidades anónimas en la configuración de los clientes, que hace que se mande la identidad anónima antes del cifrado (la cual debería ser igual para todos los usuarios) y una vez se crea el túnel cifrado se envía la identidad real. Al ser una configuración de los clientes es muy habitual encontrar que no se hace uso de identidades anónimas, por lo que es posible obtener los nombres de usuario.

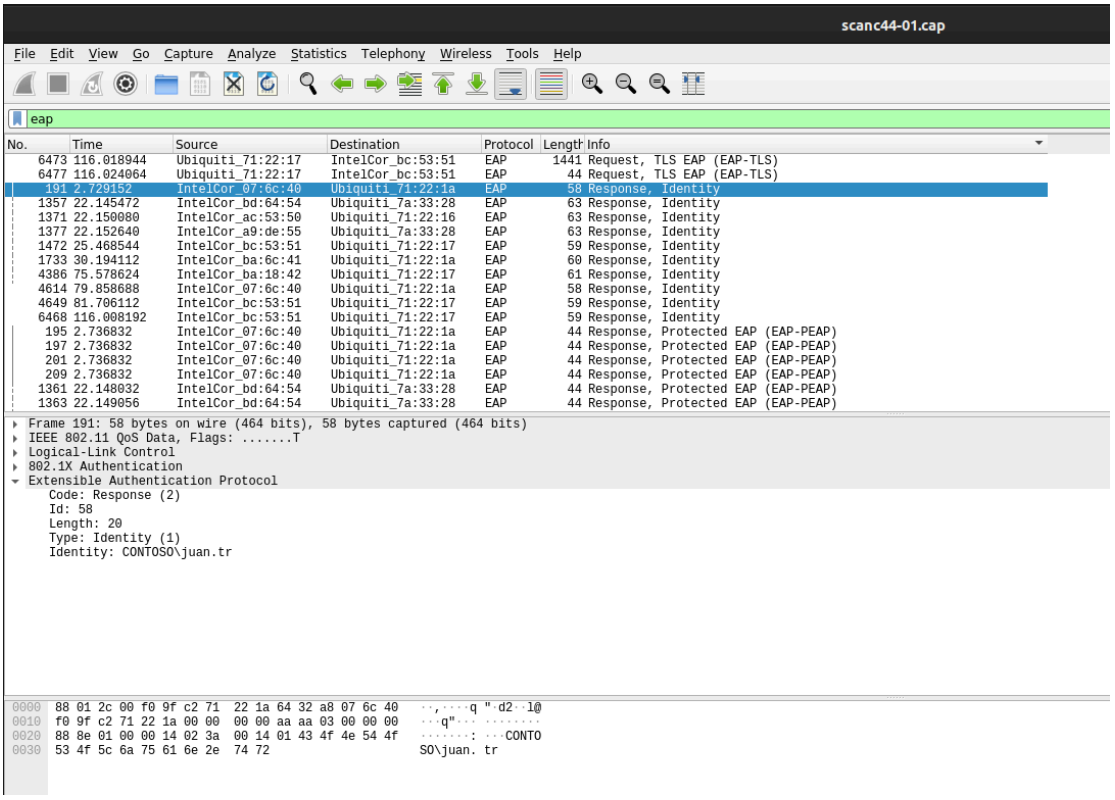
Una práctica común es capturar las identidades (nombres de usuario) transmitidas en texto claro antes de que se establezca un túnel seguro como TLS. Esta información se puede recolectar de manera pasiva usando herramientas como airodump-ng.

```
airodump-ng wlan0mon -w /home/user/wifi/scanc44 -c 44 --wps
```

Posteriormente, se puede analizar el archivo de captura con herramientas como Wireshark.

```
wireshark /home/user/wifi/scanc44-01.cap
```

En Wireshark se filtran los paquetes por eap y se busca la respuesta de identidad para obtener nombres de usuario.



Wireshark con filtro EAP para obtener Identidades

Alternativamente, se puede usar la herramienta wifi_db para extraer esta información de forma más automatizada.

```
cd /root/tools/wifi_db
python3 wifi_db.py -d wifidata.SQLITE /home/user/wifi/
```

Para la visualización en SQLite podemos abrirlo con sqlitebrowser:

```
sqlitebrowser wifidata.SQLITE
```

Y abrir la tabla de IdentityAP:

Database Structure | Browse Data | Edit Pragmas | Execute SQL

Table: IdentityAP

	bssid	ssid	mac	manuf	identity	method
	Filter	Filter	Filter	Filter	Filter	Filter
1	F0:9F:C2:7A:33:28	wifi-regional-tablets	64:32:A8:A9:DE:55	Intel Corporate	[redacted]	EAP-PEAP
2	F0:9F:C2:7A:33:28	wifi-regional-tablets	64:32:A8:BD:64:54	Intel Corporate	[redacted]	EAP-PEAP
3	F0:9F:C2:71:22:16	wifi-regional	64:32:A8:AC:53:50	Intel Corporate	[redacted]	EAP-PEAP
4	F0:9F:C2:71:22:17	wifi-global	64:32:A8:BA:18:42	Intel Corporate	GLOBAL\GlobalAdmin	EAP-TLS
5	F0:9F:C2:71:22:17	wifi-global	64:32:A8:BC:53:51	Intel Corporate	GLOBAL\anonymous	EAP-TLS
6	F0:9F:C2:71:22:15	wifi-corp	64:32:A8:07:6C:40	Intel Corporate	CONTOSO\juan.tr	EAP-PEAP
7	F0:9F:C2:71:22:1A	wifi-corp	64:32:A8:BA:6C:41	Intel Corporate	CONTOSO\anonymous	EAP-PEAP

Información de identidades en base de datos de wifi_db

Otra opción es utilizar tshark para filtrar los paquetes que contienen identidades EAP directamente desde la línea de comandos:

```
tshark -r /home/user/wifi/scan-01.cap -Y '(eap && wlan.ra == xx:xx:xx:xx:xx:xx) && (eap.identity)' -T fields -e eap.identity
```

- /home/user/wifi/scan-01.cap es la ubicación del archivo de captura de paquetes.
- xx:xx:xx:xx:xx:xx es la dirección MAC de destino específica que se desea filtrar, es decir, la MAC del AP.
- -Y '(eap && wlan.ra == xx:xx:xx:xx:xx:xx) && (eap.identity)' es el filtro de visualización que especifica que solo se deben considerar los paquetes EAP con la dirección MAC de destino dada y que contienen un identificador EAP.
- -T fields -e eap.identity configura la salida para mostrar solo el campo de identificación EAP.

Existen varios tipos de identidades que se pueden emplear en la infraestructura, y cada uno ofrece un nivel distinto de información. Entre ellos, se encuentran las identidades estándar, como el nombre de usuario simple (usuario), el User Principal Name (UPN) que combina el usuario y dominio (usuario@dominio.com), el SAMAccountName en formato de dominio y usuario (dominio\usuario), y la dirección de correo electrónico (correo@dominio.com). Además, en ciertas configuraciones específicas pueden usarse atributos personalizados como el número de empleado u otros atributos en plataformas como Azure en el caso de integraciones con la nube de Microsoft.

Por otro lado, cuando se emplea una identidad anónima, aún es posible obtener cierto grado de información. Esto se debe a que muchos administradores configuran la identidad anónima incluyendo el nombre de dominio, lo que permite identificar el dominio con solo monitorizar la red. Por ejemplo, en el formato CONTOSO\anonymous o anonymous@CONTOSO.local es evidente el nombre de dominio.

Análisis de Certificados de los AP

El establecimiento de un túnel TLS entre un cliente y un servidor (AP) implica el envío del certificado del servidor en texto claro ya que se utiliza cifrado asimétrico y se envía la parte pública del certificado. Esta información puede ser interceptada y usada en ataques como RogueAP o para recolectar información sobre los dominios corporativos.

Se puede utilizar el script pcapFilter.sh para extraer certificados desde archivos de captura.

```
cd /root/tools/
bash pcapFilter.sh -f /home/user/wifi/scan-02.cap -C
```

```
root@WlFlChallengeLab:~/tools/wifi_db# cd /root/tools/
root@WlFlChallengeLab:~/tools# bash pcapFilter.sh -f /home/user/wifi/wlflc44-01.cap -C

FILE: /home/user/wifi/wlflc44-01.cap
Running as user "root" and group "root". This could be dangerous.
Certificate:
    Data:
        Version: 3 (0x2)
        Serial Number: 2 (0x2)
        Signature Algorithm: sha256WithRSAEncryption
        Issuer: C = ES, ST = Madrid, L = Madrid, O = WlFlChallengeLab, OU = Certificate Authority, CN = WlFlChallengeLab CA, emailAddress = [redacted]
        Validity
            Not Before: Feb 19 17:49:46 2023 GMT
            Not After : Feb 18 17:49:46 2025 GMT
        Subject: C = ES, L = Madrid, O = WlFlChallengeLab, OU = Server, CN = WlFlChallengeLab CA, emailAddress = [redacted]
        Subject Public Key Info:
            Public Key Algorithm: rsaEncryption
                RSA Public-Key: (2048 bit)
                Modulus:
                    00:a3:cf:b8:a3:4b:19:22:0d:c1:c4:1e:7f:bb:eb:
                    ef:f3:ea:3c:3b:95:17:f6:3f:1f:82:23:6c:21:23:
                    6f:15:4c:8f:7b:3e:30:8d:e1:79:4a:91:23:3e:12:
                    70:e0:41:54:66:04:64:fb:42:85:59:64:d4:18:a4:
```

Información del certificado del AP

Ahí podemos ver toda la información del certificado, siendo lo más importante la línea de Issuer, que son los campos de texto de la CA que ha firmado ese certificado y los de Subject que son los campos de texto del certificado final, es decir, el certificado del AP.

En Wireshark, los certificados pueden ser filtrados usando el BSSID del AP.

```
(wlan.sa == xx:xx:xx:xx:xx:xx) && (tls.handshake.certificate)
```

Para tshark, el comando sería:

```
tshark -r /home/user/wifi/scan-02.cap -Y "wlan.bssid == xx:xx:xx:xx:xx:xx && ssl.handshake.type == 11" -V
```

Métodos de Autenticación EAP

Una vez se dispone de un usuario válido, se pueden probar diversos métodos de autenticación EAP soportados por el AP utilizando herramientas como EAP_buster, esto nos permite conocer que métodos de autenticación están soportados en el AP.

> **Note**
>
> En el siguiente capitulo vemos con más profundidad cómo funcionan los métodos EAP y que diferencias hay entre ellos.

Esta herramienta tiende a dar falsos negativos si otro programa utiliza la interfaz a la vez, por lo que es recomendable verificar que no hay nada usando esa interfaz o ejecutar airmon-ng check kill antes de ejecutarlo. En este paso es muy importante utilizar una Identidad válida siendo las anónimas inválidas para la prueba, por lo que es importante realizar el paso de monitorización para obtener identidades válidas.

```
cd /root/tools/EAP_buster/
bash ./EAP_buster.sh ssid 'DOMAIN\User' wlan1
```

```
root@WiFiChallengeLab:~/tools/EAP_buster# bash ./EAP_buster.sh wifi-corp 'CONTOSO\juan.tr' wlan1

EAP_buster by BlackArrow [https://github.com/blackarrowsec/EAP_buster]

WARNING
You need to use legitimate EAP identities in order to start the 802.1X authentication process and get reliable results (EAP identites can be collected using sniffing tools such as
 crEAP, just make sure you use a real identity and not an anonymous one => https://github.com/Snizz/crEAP)

supported      =>  EAP-TLS
supported      =>  EAP-PEAP_MSCHAPv2
supported      =>  EAP-PEAP_TLS
supported      =>  EAP-PEAP_GTC
supported      =>  EAP-PEAP_OTP
supported      =>  EAP-PEAP_MD5-Challenge
supported      =>  EAP-TTLS_EAP-MD5-Challenge
supported      =>  EAP-TTLS_EAP-GTC
supported      =>  EAP-TTLS_EAP-OTP
supported      =>  EAP-TTLS_EAP-MSCHAPv2
supported      =>  EAP-TTLS_EAP-TLS
supported      =>  EAP-TTLS_MSCHAPv2
supported      =>  EAP-TTLS_MSCHAP
supported      =>  EAP-TTLS_PAP
supported      =>  EAP-TTLS_CHAP
supported      =>  EAP-FAST_MSCHAPv2
supported      =>  EAP-FAST_GTC
supported      =>  EAP-FAST_OTP
```

Uso de EAP búster para verificar los métodos soportados

Esta información inicialmente parece que no puede ser de utilidad, ya que si el AP soporta todos los métodos pero los clientes utilizan un método seguro como EAP-TLS no es posible atacar la comunicación de esos clientes, pero es muy útil para descartar redes que, por ejemplo, solo soportan EAP-TLS, y no vamos a poder atacar o para detectar el nivel de seguridad general configurado. Si soporta todos los métodos suele significar que el equipo de Sistemas no le ha puesto mucho esfuerzo a securizar la red, por lo que es muy posible que haya clientes mal configurados conectados a la red.